

POLÍTICA DE GERENCIAMENTO DE RISCOS DE TI

Monstros S.A.

Código do documento:
POL-RISK-001

Classificação: Uso Interno

Versão atual: 1.0

Histórico de Revisões

Versão	Data	Descrição da alteração	Autor	Aprovado por
1.0	01/03/2026	Emissão inicial do documento	Marina Kowalski, Analista de Riscos	Renato Bousquet, CISO

1. Objetivo

Esta política estabelece as diretrizes para identificação, análise, tratamento e monitoramento dos riscos de tecnologia da informação na Monstros S.A., assegurando que ameaças à segurança, disponibilidade e integridade dos ativos de TI sejam geridas de forma consistente e proporcional ao seu impacto no negócio.

2. Escopo

Aplica-se a todas as áreas, sistemas, projetos e fornecedores que utilizam ou dão suporte à infraestrutura de tecnologia da Monstros S.A., incluindo colaboradores próprios, terceiros e parceiros com acesso a esses ativos.

3. Definições

- Risco de TI:** possibilidade de um evento comprometer a confidencialidade, integridade ou disponibilidade de um ativo de tecnologia.
- Plano de Ação:** conjunto de medidas definidas para reduzir a probabilidade ou o impacto de um risco identificado.
- Matriz de Risco:** ferramenta que combina impacto e probabilidade para classificar a criticidade de um risco.

4. Diretrizes Gerais

Todo risco de TI identificado deve ser formalmente registrado no Cadastro de Riscos, com sua categoria, origem e resultado potencial descritos de forma clara, de modo que qualquer pessoa do Comitê de Riscos consiga compreender a natureza da ameaça sem depender de explicações verbais adicionais.

Riscos classificados como Alto ou Muito Alto exigem a definição de um plano de ação formal, com responsável nomeado e prazo estabelecido; nesses casos, o acompanhamento deixa de ser opcional e passa a fazer parte da pauta recorrente do Comitê de Riscos até que o risco seja reduzido a um nível aceitável.

A priorização do tratamento segue a pontuação da matriz de risco, calculada pela multiplicação entre impacto e probabilidade; quanto maior a pontuação, mais cedo o risco deve entrar na fila de tratamento em relação aos demais itens do portfólio, independentemente da ordem em que foram identificados.

Riscos sem plano de ação associado devem ser reavaliados a cada ciclo de monitoramento, para verificar se a ausência de tratamento ainda é justificável — seja por baixa criticidade, seja por decisão formal de aceitação do risco — ou se as condições mudaram e o risco passou a exigir ação.

A ausência de registro de um risco conhecido não isenta a área responsável de sua gestão; o desconhecimento formal por parte do Comitê de Riscos não elimina a exposição real da organização, e a responsabilidade pelo dano potencial permanece com a área que detinha o conhecimento do risco.

5. Processo

O gerenciamento de um risco de TI segue um ciclo de vida com seis etapas, desde sua origem até seu encerramento formal:

- 1 **Identificação** — o risco é reconhecido por qualquer colaborador, área ou processo de auditoria, a partir de um ponto de gatilho observável (uma vulnerabilidade, um incidente, uma mudança de cenário).
- 2 **Cadastro** — o risco é formalmente registrado no Cadastro de Riscos, com categoria, fonte, data de levantamento e responsável pela identificação.
- 3 **Análise e Classificação** — impacto e probabilidade são avaliados, gerando a pontuação da matriz de risco e sua classificação qualitativa (Baixo, Médio, Alto ou Crítico).
- 4 **Definição do Plano de Ação** — para riscos que exigem tratamento, é definido um plano de ação com objetivo claro, responsável nomeado e prazo, com foco em reduzir a probabilidade, o impacto, ou ambos.
- 5 **Acompanhamento** — o andamento do plano de ação é monitorado periodicamente pelo responsável e revisado pelo Comitê de Riscos, que pode ajustar prazos, prioridades ou a própria estratégia de tratamento.
- 6 **Encerramento** — uma vez mitigado, o risco é reavaliado para confirmar a eficácia do tratamento e formalmente encerrado no Cadastro de Riscos, com data e evidências do fechamento.

6. Papéis e Responsabilidades

Papel	Responsabilidade	Responsável
CISO	Aprovação da política e decisões sobre riscos críticos	Renato Bousquet
Comitê de Riscos	Revisão periódica do portfólio de riscos e planos de ação	Presidido por Alana Ferreira, Diretora de TI
Analista de Riscos	Registro, análise e acompanhamento dos riscos	Marina Kowalski
Gestores de Área	Execução dos planos de ação sob sua responsabilidade	Conforme Cadastro de Riscos

7. Revisão da Política

Esta política deve ser revisada anualmente, ou sempre que houver mudança relevante no ambiente de TI, na estrutura organizacional ou na legislação aplicável.

8. Aprovação

Documento aprovado por Renato Bousquet, CISO da Monstros S.A., em 01/03/2026.